

Registre des risques — PNPI

*Document interne vivant · Architecture PNPI · Version 1.0 — Avril 2026 Auteur : Jean Baptiste
MBA NDONG (Architecte / Concepteur) Revue trimestrielle (T1, T2, T3, T4)*

1. Méthode

- **Probabilité** : 1 (très improbable) → 5 (quasi certain à 12 mois).
- **Impact** : 1 (négligeable) → 5 (catastrophique, mission menacée).
- **Score** : Probabilité × Impact (1 à 25).
- **Plan de réponse** :
 - **Évite** : on supprime la cause.
 - **Réduit** : on diminue probabilité ou impact.
 - **Transfère** : assurance, sous-traitance, contractualisation tiers.
 - **Accepte** : risque résiduel assumé, surveillé.
- **Statut** : Ouvert / En cours de mitigation / Mitigé / Survenu / Clos.

Sauf mention contraire, l'**owner** est le concepteur tant qu'aucune équipe de gouvernance n'est nommée. Cible : transférer la majorité au Ministère / ANINF dans les 12 mois.

2. Synthèse

INDICATEUR	VALEUR
Risques répertoriés	30
Score moyen	8,4
Risques critiques (score ≥ 16)	5
Risques majeurs (score 12-15)	9
Risques modérés (score 6-11)	11
Risques mineurs (score ≤ 5)	5

3. Top 5 critiques (score ≥ 16)

ID	RISQUE	P	I	SCORE	OWNER
R-022	Indisponibilité du concepteur (bus factor 1)	4	5	20	Concepteur → Cabinet
R-001	Compromission de PNPI_SECRET_KEY ou base utilisateurs	3	5	15	Concepteur
R-003	Perte irréversible des documents ATI (filesystem non répliqué)	3	5	15	Concepteur + ANINF
R-007	Incident majeur datacenter ANINF (>4h indispo)	3	5	15	ANINF
R-014	Non-renouvellement annuel du forfait par changement politique	3	5	15	Cabinet

4. Registre détaillé (par catégorie)

A. Risques techniques

R-001 — Compromission de la clé JWT ou de la base utilisateurs

- **Catégorie** : Sécurité
- **Description** : extraction de `PNPI_SECRET_KEY` (commit accidentel, fuite par prestataire, attaque chaîne de fournisseurs) → faux JWT acceptés, accès admin compromis.
- **P/I/Score** : 3/5/15
- **Mitigation actuelle** : `.env` ignoré par git, secret unique par env.
- **Plan : Réduit** — Vault/KMS (cf. dette D-012), rotation trimestrielle, passage RS256 (ADR-001 suivi).
- **Statut** : Ouvert. Date cible mitigation : T+90 jours.

R-002 — IDOR sur endpoints opérateur (vol croisé de données)

- **Catégorie** : Sécurité applicative
- **Description** : un endpoint `/pnpi/ati/{id}/*` ouvert à `Role.opérateur` oublie d'appeler `check_ati_access` → exposition des dossiers d'industriels concurrents.
- **P/I/Score** : 2/5/10
- **Mitigation actuelle** : helper centralisé `check_ati_access`, doc CLAUDE.md, tests `test_opérateur_endpoints.py`.
- **Plan : Réduit** — linter CI dédié (cf. ADR-002 suivi), revue de code obligatoire sur tout nouveau router opérateur.
- **Statut** : Mitigé partiellement. Revue continue.

R-003 — Perte irrémédiable des documents ATI

- **Catégorie** : Données / Infrastructure
- **Description** : `uploads/ati` est un volume Docker local non répliqué. Une corruption disque = perte historique des justificatifs.
- **P/I/Score** : 3/5/15
- **Mitigation actuelle** : aucune réplication automatisée.
- **Plan : Réduit** — migration MinIO + réplication 3 nœuds + backup hors-site. Cf. dette D-001.
- **Statut** : Ouvert. Date cible : T+30 jours.

R-004 — Faille SQL injection / NoSQL injection

- **Catégorie** : Sécurité applicative

- **Description** : injection via paramètre non sanitisé.
- **P/I/Score** : 2/4/8
- **Mitigation actuelle** : SQLAlchemy ORM (paramétrage automatique), Pydantic schemas, `core/sanitize.py` .
- **Plan : Réduit** — pentest J+15, durcissement.
- **Statut** : Mitigé partiellement.

R-005 — DoS / déni de service via abus API

- **Catégorie** : Performance / Disponibilité
- **Description** : un opérateur (ou attaquant) sature les endpoints publics.
- **P/I/Score** : 3/4/12
- **Mitigation actuelle** : rate limiter `core/rate_limiter.py` , CSRF, taille upload limitée.
- **Plan : Réduit** — WAF ANINF + monitoring d'anomalies.
- **Statut** : En cours de mitigation.

R-006 — Échec de migration Alembic en production

- **Catégorie** : Données
- **Description** : une migration Alembic échoue mid-transaction → base incohérente.
- **P/I/Score** : 2/5/10
- **Mitigation actuelle** : tests CI sur base vierge.
- **Plan : Réduit** — replay sur base prod-like avant chaque release (cf. dette D-010), backup pré-migration obligatoire.
- **Statut** : Ouvert. Date cible : T+60 jours.

R-007 — Incident majeur datacenter ANINF

- **Catégorie** : Infrastructure / Disponibilité
- **Description** : panne électrique, climatisation, incendie au DC Libreville. Indisponibilité PNPI > 4h.
- **P/I/Score** : 3/5/15
- **Mitigation actuelle** : SLA ANINF 99,5 %, redondance électrique documentée.
- **Plan : Réduit + Transfère** — réplique site secondaire ANINF (AZ-B), test de bascule trimestriel, contrat SLA renforcé.
- **Statut** : Ouvert. Date cible : T+180 jours.

R-008 — Charge supérieure aux hypothèses

- **Catégorie** : Performance
- **Description** : 1000 utilisateurs concurrents non testés.

- **P/I/Score** : 2/4/8
- **Mitigation actuelle** : aucune (cf. dette D-004).
- **Plan** : **Réduit** — tests de charge, autoscaling horizontal.
- **Statut** : Ouvert. Date cible : T+45 jours.

R-009 — Vulnérabilité critique sur dépendance tierce (CVE)

- **Catégorie** : Sécurité applicative
- **Description** : une CVE critique sur FastAPI, Pydantic, Next.js, etc.
- **P/I/Score** : 4/3/12
- **Mitigation actuelle** : `pip-audit` + `npm audit` en CI.
- **Plan** : **Réduit** — Dependabot + processus de patch <72h.
- **Statut** : En cours de mitigation.

R-010 — Régression majeure post-déploiement

- **Catégorie** : Qualité
- **Description** : un commit casse le workflow ATI en production.
- **P/I/Score** : 3/4/12
- **Mitigation actuelle** : CI sur PR, tests E2E Playwright.
- **Plan** : **Réduit** — environnement staging iso-prod, tests E2E étendus, déploiement progressif (canary).
- **Statut** : En cours de mitigation.

B. Risques juridiques et conformité

R-011 — Refus de la CNPDCP du dépôt de traitement

- **Catégorie** : Conformité
- **Description** : la CNPDCP gabonaise refuse ou retarde l'autorisation du traitement « PNPI ».
- **P/I/Score** : 2/4/8
- **Mitigation actuelle** : aucune ; dépôt à préparer J+1 → J+15.
- **Plan** : **Réduit** — préparation rigoureuse du dossier, juriste spécialisé.
- **Statut** : Ouvert.

R-012 — Litige avec un industriel sur la valeur probante d'un acte

électronique - **Catégorie** : Juridique - **Description** : un industriel sanctionné conteste devant le tribunal la signature électronique de la décision. - **P/I/Score** : 2/4/8 - **Mitigation actuelle** : signature manuscrite encore en cours d'utilisation. - **Plan** : **Réduit** — passage à signature avancée puis qualifiée (ADR-005). - **Statut** : Ouvert. Mitigation phase 1 à T+12 mois.

R-013 — Différend sur la propriété intellectuelle

- **Catégorie** : Juridique
- **Description** : un agent du Ministère revendique la co-propriété de la PNPI au motif d'une contribution antérieure.
- **P/I/Score** : 1/5/5
- **Mitigation actuelle** : convention de cession d'usage formelle (cf. docs/strategie/04).
- **Plan** : **Évite** — convention claire à la signature, journal de développement horodaté (git history), preuve antériorité concepteur.
- **Statut** : En cours de mitigation.

R-014 — Non-renouvellement du forfait par changement politique

- **Catégorie** : Commercial / Politique
- **Description** : changement de Ministre / cabinet ; nouvelle équipe décide de ne pas renouveler le forfait annuel.
- **P/I/Score** : 3/5/15
- **Mitigation actuelle** : visibilité institutionnelle PNPI (audience ministre validée 30.03.26).
- **Plan** : **Réduit** — convention pluriannuelle 3 ans (objectif négociation), reconnaissance publique du dispositif, indicateurs d'usage tangibles dès T+90.
- **Statut** : Ouvert. Mitigation à la signature.

R-015 — Mise en concurrence forcée par appel d'offres

- **Catégorie** : Juridique / Commercial
- **Description** : la Direction des Marchés Publics impose un appel d'offres sur la maintenance.
- **P/I/Score** : 2/4/8
- **Mitigation actuelle** : posture C hybride retenue (don d'usage perpétuel) → pas un marché public au sens strict.
- **Plan** : **Évite** — formulation juridique de la convention en « partenariat institutionnel » et non « prestation ». Avis juridique préalable à confirmer.
- **Statut** : En cours de mitigation.

R-016 — Non-conformité à la loi 042/2021 sur les transactions

électroniques - **Catégorie** : Conformité - **Description** : une fonctionnalité (signature, horodatage) ne respecte pas le cadre légal local. - **P/I/Score** : 2/3/6 - **Mitigation actuelle** : audit juridique informel. - **Plan** : **Réduit** — audit juridique formel à T+30 jours. - **Statut** : Ouvert.

C. Risques opérationnels

R-017 — Adoption insuffisante par les inspecteurs

- **Catégorie** : Adoption / Métier
- **Description** : les inspecteurs continuent à utiliser leurs outils (papier, Excel) malgré la PNPI.
- **P/I/Score** : 3/4/12
- **Mitigation actuelle** : formation prévue J+15 → J+30.
- **Plan** : **Réduit** — sponsor Cabinet, gamification, suivi nominatif.
- **Statut** : Ouvert.

R-018 — Refus opérateurs industriels (papier persistant)

- **Catégorie** : Adoption
- **Description** : les opérateurs industriels (PME locales) ne se connectent pas à la PNPI, continuent les démarches papier.
- **P/I/Score** : 4/3/12
- **Mitigation actuelle** : guichet opérateur ergonomique en place.
- **Plan** : **Réduit** — communication sectorielle, période de coexistence 3 mois, basculement obligatoire à T+6 mois.
- **Statut** : Ouvert.

R-019 — Données initiales (référentiel opérateurs) erronées

- **Catégorie** : Données / Adoption
- **Description** : la migration depuis les fichiers papier introduit des erreurs (fautes de saisie, doublons, NIF incorrects).
- **P/I/Score** : 4/3/12
- **Mitigation actuelle** : modèle soft-delete, audit d'intégrité.
- **Plan** : **Réduit** — chantier qualité données J+30 → J+60, croisement avec DGI/RCCM.
- **Statut** : Ouvert.

R-020 — Délai d'instruction allongé en phase pilote

- **Catégorie** : Métier
- **Description** : le délai d'instruction observé dépasse les cibles (15j) car les agents apprennent l'outil.
- **P/I/Score** : 4/2/8
- **Mitigation actuelle** : SLA progressifs (objectif glissant).
- **Plan** : **Accepte** — communication transparente, bilan T+90 jours.
- **Statut** : Accepté.

R-021 — Surcharge de support post-ouverture

- **Catégorie** : Opérationnel

- **Description** : trop de tickets, le concepteur seul ne tient pas l'astreinte.
- **P/I/Score** : 4/3/12
- **Mitigation actuelle** : aucune.
- **Plan : Réduit** — recrutement support N1 dès T+30 jours, FAQ interne, tutoriels vidéo.
- **Statut** : Ouvert.

R-022 — Indisponibilité du concepteur (bus factor 1)

- **Catégorie** : Humain / Continuité
- **Description** : le concepteur seul détient toute la connaissance. Maladie, accident, opportunité externe → la PNPI s'arrête.
- **P/I/Score** : 4/5/20
- **Mitigation actuelle** : documentation `CLAUDE.md` , ADR, dette technique, runbooks en cours.
- **Plan : Réduit + Transfère** — recrutement appui T+1 mois, jumelage ANINF, transfert de compétences contractuel à 12 mois, documentation exhaustive (cible : tout repreneable par un dev senior en 30 jours).
- **Statut** : Ouvert. **Risque le plus élevé du registre.**

R-023 — Difficulté à recruter sur la stack PNPI au Gabon

- **Catégorie** : Humain
- **Description** : peu d'ingénieurs FastAPI + Next.js + PostGIS disponibles localement.
- **P/I/Score** : 4/3/12
- **Mitigation actuelle** : aucune.
- **Plan : Réduit** — partenariat IAI Gabon (formation continue), recrutement régional (Cameroun, Sénégal), télétravail accepté.
- **Statut** : Ouvert.

R-024 — Procès-verbal de litige RH (succession PNPI)

- **Catégorie** : Humain / Juridique
- **Description** : litige avec un futur employé / prestataire (NDA, cession code, etc.).
- **P/I/Score** : 2/3/6
- **Mitigation actuelle** : aucune.
- **Plan : Réduit** — contrats types relus par un juriste, NDA systématique, gestion comptes utilisateurs (révocation immédiate).
- **Statut** : Ouvert.

D. Risques liés au déploiement CEMAC

R-025 — Aucun pays CEMAC ne signe pour la PNPI

- **Catégorie** : Commercial
- **Description** : 24 mois après l'ouverture officielle, aucun pays partenaire n'a souscrit.
- **P/I/Score** : 3/3/9
- **Mitigation actuelle** : posture C qui maintient l'option ouverte.
- **Plan** : **Accepte** — la PNPI reste viable sur le seul Gabon ; l'expansion CEMAC est un *upside*, pas une condition de survie.
- **Statut** : Accepté avec surveillance.

R-026 — Concurrence d'un éditeur international (SAP, Oracle)

- **Catégorie** : Commercial
- **Description** : un grand éditeur lance une offre Public Sector pour la CEMAC.
- **P/I/Score** : 3/3/9
- **Mitigation actuelle** : différenciation par souveraineté, prix, langue, time-to-market.
- **Plan** : **Réduit** — *go-to-market* CEMAC rapide (T+12 mois) avant que la concurrence se positionne.
- **Statut** : Ouvert.

R-027 — Tension diplomatique avec un État voisin

- **Catégorie** : Politique
- **Description** : crise diplomatique entre le Gabon et un État partenaire CEMAC.
- **P/I/Score** : 2/3/6
- **Mitigation actuelle** : posture « éditeur privé » (pas d'engagement d'État à État).
- **Plan** : **Accepte** — le contrat lie la structure juridique du concepteur au pays client, pas le Gabon.
- **Statut** : Accepté.

E. Risques transversaux

R-028 — Détournement d'usage de la PNPI à des fins politiques

- **Catégorie** : Réputation / Politique
- **Description** : la PNPI sert à justifier une décision discriminatoire contre un industriel pour raisons non métier.
- **P/I/Score** : 2/4/8

- **Mitigation actuelle** : audit complet (`core/audit.py`) de toutes les actions, traçabilité décisionnelle.
- **Plan : Réduit** — audit indépendant annuel de l'usage.
- **Statut** : Ouvert.

R-029 — Coût opérationnel CEMAC sous-estimé

- **Catégorie** : Financier
- **Description** : la maintenance de N tenants CEMAC coûte plus que prévu.
- **P/I/Score** : 4/2/8
- **Mitigation actuelle** : tarification par pays adaptée.
- **Plan : Réduit** — comptabilité analytique par tenant dès T+12 mois.
- **Statut** : Ouvert.

R-030 — Image négative liée à un incident public

- **Catégorie** : Réputation
- **Description** : fuite de données, indisponibilité prolongée, bug visible à la presse.
- **P/I/Score** : 2/4/8
- **Mitigation actuelle** : monitoring, communication de crise informelle.
- **Plan : Réduit** — plan de communication de crise formel à T+60 jours, porte-parole identifié, FAQ pré-rédigée.
- **Statut** : Ouvert.

5. Risques triés par score décroissant

ID	RISQUE	SCORE	STATUT	OWNER
R-022	Bus factor 1 (concepteur)	20	Ouvert	Concepteur → Cabinet
R-001	Compromission JWT/users	15	Ouvert	Concepteur
R-003	Perte documents ATI	15	Ouvert	Concepteur + ANINF
R-007	DC ANINF indispo	15	Ouvert	ANINF
R-014	Non-renouvellement politique	15	Ouvert	Cabinet
R-005	DoS API	12	En cours	Concepteur
R-009	CVE dépendance tierce	12	En cours	Concepteur
R-010	Régression post-deploy	12	En cours	Concepteur
R-017	Refus inspecteurs	12	Ouvert	Cabinet
R-018	Refus opérateurs	12	Ouvert	Cabinet
R-019	Données initiales sales	12	Ouvert	DGI Industrie
R-021	Surcharge support	12	Ouvert	Concepteur
R-023	Recrutement local difficile	12	Ouvert	Concepteur
R-002	IDOR opérateur	10	Mitigé partiel	Concepteur
R-006	Échec migration Alembic	10	Ouvert	Concepteur
R-025	Pas d'adoption CEMAC	9	Accepté	Concepteur
R-026	Concurrence internationale	9	Ouvert	Concepteur
R-004	SQL injection	8	Mitigé partiel	Concepteur
R-008	Sur-charge perf	8	Ouvert	Concepteur
R-011	Refus CNPDCP	8	Ouvert	Cabinet + concepteur
R-012	Litige signature électronique	8	Ouvert	Cabinet

ID	RISQUE	SCORE	STATUT	OWNER
R-015	Appel d'offres forcé	8	En cours	Cabinet
R-020	Délai instruction allongé	8	Accepté	Cabinet
R-028	Détournement politique	8	Ouvert	Cabinet
R-029	Coût CEMAC sous-estimé	8	Ouvert	Concepteur
R-030	Image négative incident	8	Ouvert	Cabinet + concepteur
R-016	Non-conformité loi 042/2021	6	Ouvert	Cabinet
R-024	Litige RH succession	6	Ouvert	Concepteur
R-027	Tension diplomatique	6	Accepté	Concepteur
R-013	Différend PI	5	En cours	Concepteur

6. Gouvernance du registre

- **Revue trimestrielle** : T1 (avril), T2 (juillet), T3 (octobre), T4 (janvier). Chaque revue produit une nouvelle version annotée.
- **Revue exceptionnelle** : sur survenue d'un risque (statut → Survenu), ou changement majeur du contexte (réorganisation Ministère, incident régional, etc.).
- **Diffusion** : interne PNPI + Cabinet du Ministère + ANINF.
- **Confidentialité** : ce document n'est pas public. Les pays CEMAC reçoivent une version expurgée des paragraphes politiques.

Fin du document.